

Mohamed MEDDAH

Cybersecurity Engineer | Cloud Security | Offensive Security

+212 653 900 305 | mohamed@meddah.systems | linkedin.com/in/meddah | github.com/mrmeddah | meddah.systems

Marrakech, Morocco | Open to relocation | Open to remote

PROFESSIONAL SUMMARY

Final-year Cybersecurity Engineering student (Bac+5 / Master's equivalent, Bologna Process EQF Level 7, expected Jun. 2027) with confirmed production bug bounty impact and cloud security tooling across Azure and AWS. Proven across offensive web and API testing, Azure RBAC privilege escalation research, and DORA-aligned defensive tooling. Proficient in English (C1) and French (B2). Seeking PFE internship in EU regulated environments from February 2027.

TECHNICAL SKILLS

Offensive Security: Penetration Testing, Web Application Security, API Security, SSRF, IDOR/BOLA, OAuth 2.0 Exploitation, GraphQL Security, Subdomain Enumeration, AD Attacks, NTLM Relay, ADCS Abuse, LFI

Cloud Security — Azure: Security Posture Management, Defender for Cloud, Microsoft Entra ID, Conditional Access, Managed Identities, Azure RBAC, Key Vault, Azure Functions, ARM Templates, Azure Monitor

Cloud Security — AWS: EC2, VPC, IAM, S3, RDS, Secrets Manager, CloudTrail, Security Hub, GuardDuty, 70+ services via Terraform IaC

Frameworks & Standards: OWASP Top 10, OWASP API Security Top 10, MITRE ATT&CK, CWE, Zero Trust, DORA, NIS2, ISO 27001

Network: TCP/IP, BGP, OSPF, VXLAN/EVPN, VLANs, pfSense, Site-to-Site VPN, GNS3, Wireshark (CCNA/CCNP level)

Security Tools: Burp Suite Professional, Nmap, Subfinder, Amass, httpx, Feroxbuster, ffuf, Shodan, truffleHog, BloodHound, Metasploit

Development: Python, Bash, JavaScript, Java, Go, C++, Django, React, Node.js

Systems: Linux (Debian/Ubuntu/Kali), Windows Server, Active Directory, Docker

PROFESSIONAL EXPERIENCE

Independent Contractor — Data Curator

Mar. 2024 – Sep. 2024

Veeva Systems

Remote

- Processed and validated large-scale structured datasets for pharmaceutical CRM pipelines; maintained data integrity and compliance standards across a multi-client regulated environment, directly applicable to NIS2/DORA data governance requirements.

IT Infrastructure Intern

April 2024

Menara Prefa

Marrakech, Morocco

- Deployed and configured pfSense firewall (packet filtering, NAT, segmentation); implemented site-to-site VPN using IPsec tunnelling.

Development & Systems Administration Intern

August 2023

Municipality of El Kelaa des Sraghna

El Kelaa, Morocco

- Built full-stack citizen ticket management application integrated with the national Chikaya platform; RBAC-based routing; Django REST / React / relational DB; Windows Server and Linux administration.

PROJECTS

Azure RBAC Privilege Escalation Mapper

September 2026

Python | Azure SDK | Microsoft Graph API | Azure Functions

- Enumerates multi-hop Azure privilege escalation paths via RBAC misconfiguration; detects the runCommand/IMDS token theft chain — a Defender for Cloud blind spot.
- Maps four attack primitives: Run Command abuse, Custom Script Extension backdoor, Role Assignment write escalation, User Data injection; outputs attacker-ready PoC commands with inline DORA Article 9 and CSSF regulatory citations.

Azure Deployment History Sanitizer

July 2026

Python | Azure Functions | ARM API | Shannon Entropy Analysis

- Serverless tool purging ARM/Bicep deployment histories that expose plaintext secrets to any Reader-level account; Shannon entropy + keyword heuristics detect credentials, SAS tokens, and connection strings.
- Three modes: aggressive purge, selective entropy-based, and audit-only; full audit trail to Azure Storage Tables for DORA compliance and CSSF audit readiness.

Zero-Trust Distributed Storage System

May 2026

Go | Java | libsodium | AES-256-GCM | ABE | JWT

- Mini-IPFS with client-side AES-256-GCM encryption (libsodium), Merkle DAG integrity, 3-node replication, and cryptographic access control via Attribute-Based Encryption and Proxy Re-Encryption; JWT Ed25519 PoP tokens with nonce-based anti-replay (TTL 30s).

AWS Cloud Infrastructure (Terraform IaC)

Feb 2025

Terraform | AWS | IAM | VPC | Secrets Manager

- Provisioned 70+ AWS services via modular Terraform on a live account: least-privilege IAM policies, Secrets Manager integration, multi-service network architecture across EC2, RDS, VPC, S3, and 60+ additional services.

EVPN/VXLAN Spine-Leaf Datacenter Fabric

2026

FRRouting | GNS3 | BGP EVPN | Linux iproute2

- Deployed EVPN/VXLAN overlay on GNS3 with FRRouting (BGP EVPN, OSPF underlay), Route Reflector, and MP-BGP L2VPN; validated MAC/IP distribution via Wireshark; identified VXLAN attack surface: BGP EVPN route poisoning and frame injection via underlay access.

BUG BOUNTY & SECURITY RESEARCH

Active Researcher — HackerOne | Intigriti | Bugcrowd (public and private programs)

Mar. 2024 – Present

- **SSRF — Unauthenticated Internal Access (CWE-918)**: Host Header auth bypass on a global advertising platform; reached live Kubernetes microservice returning production data.
- **OAuth Account Takeover (High)**: redirect_uri validation bypass on GitLab SSO flow — 1-click account takeover on an artifact repository via authorization code grant misconfiguration.
- **Attack Chain — Critical (CVSS 9.1)**: Unauthenticated account creation chained with Django DEBUG mode leaking cloud credentials and JWT secrets, then BOLA/IDOR to full attendee PII exfiltration (CWE-200, CWE-284).
- **API & Info Disclosure**: Exposed Swagger UI, Spring Boot Actuator, internal IP leakage on enterprise IoT/B2B SaaS; extracted API constants from obfuscated JS bundles.
- **Credential Exposure (CWE-548)**: Unauthenticated AI API keys, search credentials, and internal endpoints live on global e-commerce infrastructure.
- **Admin Interface Exposure**: JBoss/WildFly admin console on telecoms infrastructure; AD FS and WS-Trust endpoint enumeration with timing analysis.
- **Methodology**: Subfinder, Amass, httpx, Shodan, Feroxbuster, ffuf, gau, Katana, truffleHog, Burp Suite Professional; OWASP Top 10, OWASP API Security Top 10, CWE classification.

CTF & LABS

- **SecDojo National CTF**: Ranked #100 / 3,500+ participants — top 3% nationally. Techniques: LSASS credential dump, BloodHound attack paths, AD CS ESC11, NTLM relay.
- **MCP/Prompt Injection Lab (NebulaAssist)**: Full attack chain — Nmap recon, SSE token extraction, hidden tool enumeration via prompt injection.

EDUCATION

State Engineer's Degree in Cybersecurity & Network Infrastructure

2024 – Jun. 2027 (expected)

EMSI — École Marocaine des Sciences de l'Ingénieur Marrakech, Morocco Bac+5 / Master's equivalent — EQF Level 7 (Bologna Process)

Specialized Technician Diploma — Network & Systems Administration

2022 – 2024

ISTA — Institut Spécialisé de Technologie Appliquée (OFPPT)

Marrakech, Morocco

CERTIFICATIONS

- AWS Certified Cloud Practitioner (CLF-C02) — Amazon Web Services Jul. 2026
- Microsoft Certified: Cloud & AI Security Engineer Associate (SC-500) — Microsoft Sep. 2026
- AWS Certified Solutions Architect — Associate (SAA-C03) — Amazon Web Services Oct. 2026

LANGUAGES

- Arabic — Native
- French — Professional proficiency (CEFR B2)
- English — Professional proficiency (CEFR C1)